DYNAMIC ACCESS CONTROL

NT541.Q11

GVHD: TS. Phan Xuân Thiện

Nhóm 6

Thành Viên

Lương Minh Anh – 22520050

Nguyễn Gia Linh – 22520768

Nguyễn Khánh Linh – 22520769

Trần Thiên Thanh – 22521367

Phạm Thị Cẩm Tiên – 22521473

Mục Lục

1 TỔNG QUAN

2 KIẾN THỨC NỀN TẢNG

3 CÔNG NGHỆ SỬ DỤNG

4 KỊCH BẢN TRIỂN KHAI

5 TỔNG KẾT

1

TỔNG QUAN

1. Tổng quan

1.1. Bối cảnh

- Mạng hiện đại ngày càng phức tạp và đa thiết bị, yêu cầu truy cập an toàn cho nhiều nhóm người dùng.
- Mối đe dọa mạng tăng mạnh: xâm nhập, DDoS, malware, rò rỉ dữ liệu...
- Mô hình kiểm soát truy cập truyền thống thiếu linh hoạt, khó thích ứng với các sự thay đổi.
- Quản lý truy cập trong mạng đám mây, ảo hóa, phân tán trở nên khó khăn và dễ sai sót.

1. Tổng quan

1.2. Đặt vấn đề

- **SDN** giúp quản lý tập trung, lập trình linh hoạt và điều phối chính sách chủ động.
- **Dynamic Access Control** xác định quyền dựa trên thuộc tính người dùng – thiết bị – tài nguyên – ngữ cảnh theo thời gian thực.
- Kết hợp SDN + Dynamic Access Control giúp nâng cao bảo mật, tự động hóa và khả năng mở rộng.

1. Tổng quan

1.3. Mục tiêu đề tài

- Phân tích các cơ chế kiểm soát truy cập trong mạng truyền thống và SDN.
- Thiết kế mô hình Dynamic Access Control dựa trên thuộc tính đa chiều.
- Đánh giá hiệu quả, bảo mật và tính khả thi của mô hình.

2

KIẾN THỨC NỀN TẢNG

2. Kiến thức nền tảng

2.1. Software-Defined Networking (SDN) & OpenFlow

- Tách biệt control plane và data plane, giúp mạng linh hoạt và dễ lập trình.
- SDN Controller quản lý tập trung, định nghĩa chính sách và điều khiển switch/router.
- OpenFlow cho phép bộ điều khiển lập trình luồng dữ liệu trực tiếp trên switch.
- Hỗ trợ tối ưu hiệu suất, tự động hóa, bảo mật và phản ứng nhanh theo thời gian thực.

2. Kiến thức nền tảng

2.2. Dynamic Access Control (DAC)

- Cơ chế kiểm soát truy cập động, dựa trên việc đánh giá thuộc tính và ngữ cảnh tại thời điểm truy cập.
- Dựa trên mô hình ABAC, linh hoạt hơn DAC, MAC, RBAC truyền thống.
- Quyền truy cập tự điều chỉnh khi thuộc tính người dùng, thiết bị hoặc môi trường thay đổi.
- Quản lý chính sách tập trung, giảm lỗi cấu hình, hỗ trợ giám sát và phát hiện bất thường.

2. Kiến thức nền tảng

2.3. ABAC – Attribute-Based Access Control

- Quyết định truy cập dựa trên thuộc tính của người dùng – tài nguyên – môi trường – hành vi.
- Chính sách truy cập được mô tả bằng các quy tắc logic kết hợp thuộc tính.
- Linh hoạt, thích ứng tốt với môi trường phân tán, đám mây và mạng động.
- Giúp quản trị tập trung, tăng tính nhất quán và giảm rủi ro sai sót cấu hình.

3

CÔNG NGHỆ SỬ DỤNG

3. Công nghệ sử dụng

3.1. Ryu Controller

- Bộ điều khiển SDN mã nguồn mở, phát triển bằng Python và kiến trúc hướng sự kiện.
- Cho phép lập trình chính sách mạng, xử lý sự kiện và tương tác với thiết bị OpenFlow.
- Hỗ trợ xây dựng các chức năng như tối ưu định tuyến, giám sát, bảo mật, kiểm soát truy cập.
- Cung cấp API mạnh, dễ mở rộng, phù hợp cho nghiên cứu và thử nghiệm SDN.

3. Công nghệ sử dụng

3.2. Open vSwitch (OVS)

- Switch ảo, mã nguồn mở dùng cho ảo hóa và môi trường SDN.
- Hỗ trợ nhiều giao thức: OpenFlow, NetFlow, sFlow, GRE, VXLAN...
- Kiến trúc kernel–user giúp tối ưu hiệu năng xử lý gói tin.
- Hoạt động như dataplane có thể lập trình bởi controller (Ryu, ONOS, ODL).
- Thành phần chủ chốt trong ảo hóa mạng và hạ tầng đám mây (như OpenStack).

3. Công nghệ sử dụng

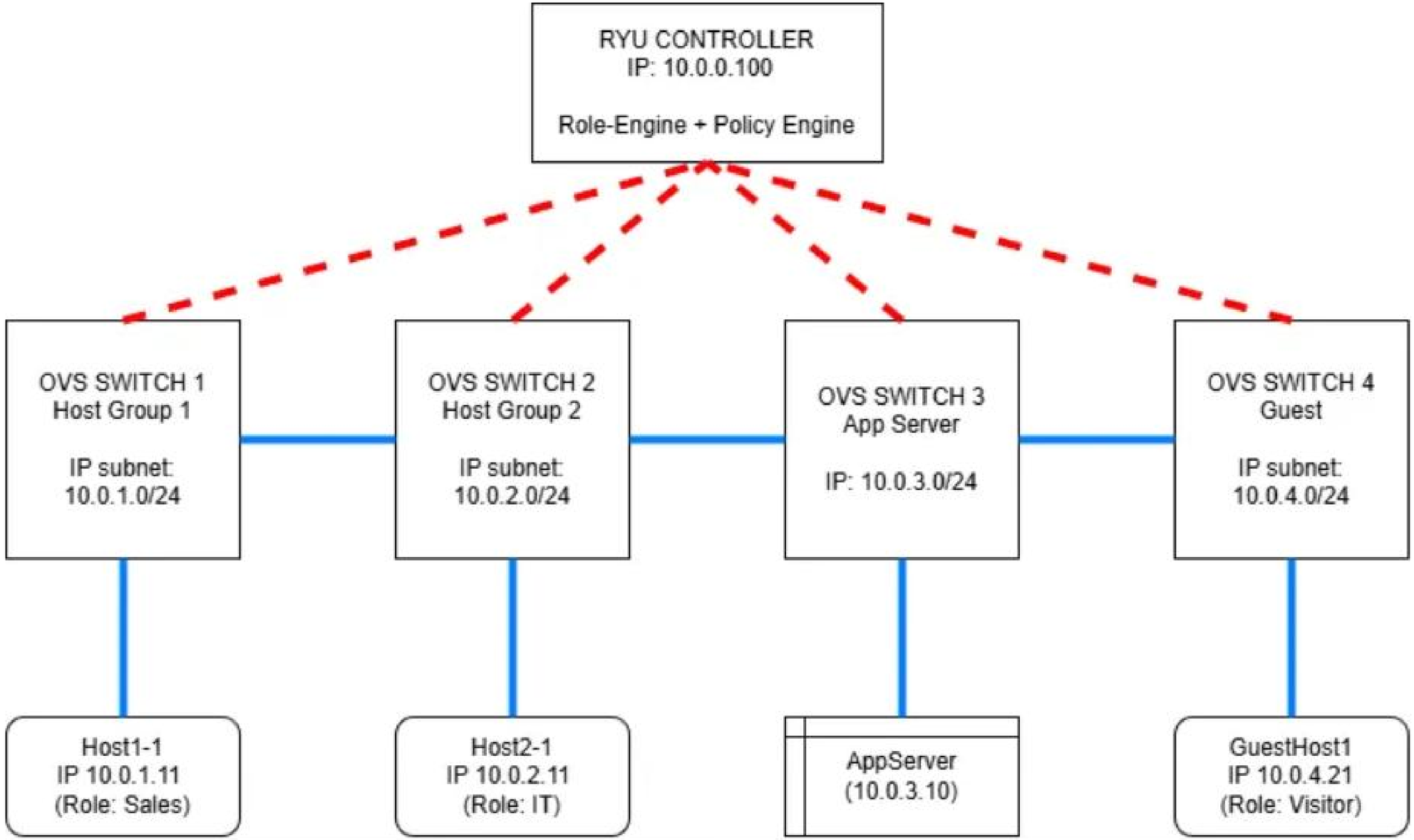
3.3. Mininet

- Công cụ mô phỏng mạng SDN nhẹ, tạo được host – switch – link ảo trên một máy.
- Cho phép kiểm thử nhanh các chính sách, giao thức và ứng dụng SDN.
- Tích hợp tốt với Ryu và OVS để mô phỏng hành vi OpenFlow gần giống mạng thật.
- Rất phù hợp cho nghiên cứu, giảng dạy và phát triển giải pháp SDN.

4

KỊCH BẢN TRIỂN KHAI

4. Kịch bản triển khai – Kiến trúc hệ thống



4. Kịch bản triển khai – Kiểm soát truy cập động dựa trên vai trò trong mạng SDN

➢ Kịch bản:

- Dựa vào subnet của địa chỉ IP để xác định vai trò của người dùng, từ đó quyết định người dùng có quyền truy cập vào tài nguyên trên server hay không.
- Ở đây, chỉ có vai trò Sales (10.0.1.0/24) và IT(10.0.2.0/24) là có quyền truy cập vào app_server (10.0.3.0/24).

```
ROLE_SUBNETS = {
    '10.0.1.0/24': 'Sales',      # Lớp mạng của Sales
    '10.0.2.0/24': 'IT',         # Lớp mạng của IT
    '10.0.4.0/24': 'Visitor'     # Lớp mạng của Visitor
}

APP_SERVER_SUBNET = '10.0.3.0/24'  # Lớp mạng của AppServer
ALLOWED_ROLES = ['Sales', 'IT']     # Các role được cho phép truy cập AppServer
```

4. Kịch bản triển khai – Kiểm soát truy cập động dựa trên vai trò trong mạng SDN

- Link video demo: https://www.youtube.com/watch?v=KsXDkk4X65A
- Các test case:
  - Test 1: Sales host ping đến IT host
  - Test 2: Sales host ping đến AppServer
  - Test 3: IT host ping đến AppServer
  - Test 4: Visitor host ping đến Sales
  - Test 5: Visitor host ping đến AppServer
  - Test 6: Unknown host ping đến Sales host
  - Test 7: Unknown host ping đến AppServer

4. Kịch bản triển khai – ABAC theo vai trò và thời gian

➢ Kịch bản:

- Hệ thống thu thập thông tin của người dùng như vai trò, thời gian truy cập, tài nguyên mong muốn và hành động đối chiếu với các chính sách để xác định được phép hay từ chối truy cập.
- Ở đây:
  - App server chứa tài liệu chung secret.txt.
  - <IT> có tất cả quyền (read, write, execute) truy cập vào tài liệu secret.txt ở mọi thời điểm.
  - <sales> có quyền đọc (read) tài liệu secret.txt trong thời gian 8h00 - 16h30.
  - <visitor> không có quyền truy cập tài liệu.

4. Kịch bản triển khai – Kiểm soát truy cập động dựa trên vai trò trong mạng SDN

```python
# Config
ROLE_SUBNETS = {
    '10.0.1.0/24': 'Sales',
    '10.0.2.0/24': 'IT',
    '10.0.4.0/24': 'Visitor'
}

APP_SERVER_SUBNET = '10.0.3.0/24'

WORK_START = time(8, 0)
WORK_END   = time(16, 30)

READ_PORTS  = [80]  # port dùng cho read file
WRITE_PORTS = [22]  # port dùng cho write file
```

```python
def _get_role(self, ip):
    try:
        ipaddr = ipaddress.ip_address(ip)
        if ipaddr in self.app_net:
            return 'AppServer'
        for net, role in self.role_networks.items():
            if ipaddr in net:
                return role
        return 'Unknown'
    except:
        return 'Unknown'

def _in_work_time(self):
    now = datetime.now().time()
    return WORK_START <= now <= WORK_END
```

4. Kịch bản triển khai – Kiểm soát truy cập động dựa trên vai trò trong mạng SDN

```python
def check_policy(self, src_ip, dst_ip, dst_port):
    role = self._get_role(src_ip)

    if ipaddress.ip_address(dst_ip) in self.app_net:
        if role == 'Visitor':
            return False, "Visitor denied access to AppServer"

        if role == 'Sales':
            if not self._in_work_time():
                return False, "Sales outside work time"
            if dst_port in READ_PORTS:
                return True, "Sales READ secret.txt"
            return False, "Sales WRITE/EXEC denied"

        if role == 'IT':
            if dst_port in READ_PORTS + WRITE_PORTS:
                return True, "IT full access"
            return False, "IT denied non-file port"

    # Allow internal traffic between hosts
    return True, "Internal allow"
```

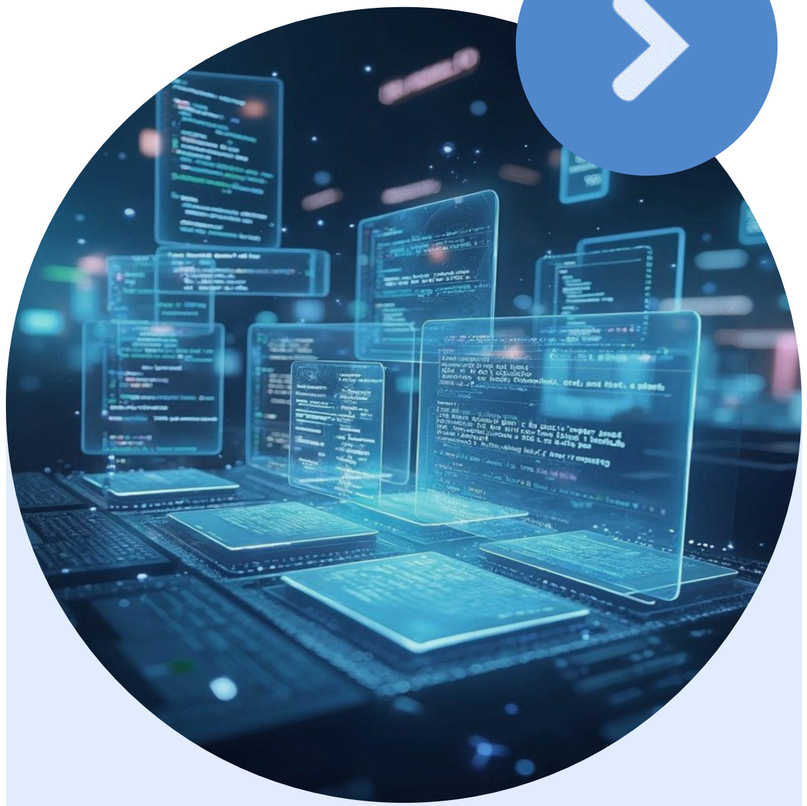
"Node: app"

```
root@ubuntu:/home/thanh/Documents/rabac# python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.0.2.1 - - [18/Dec/2025 07:03:46] "GET /secret.txt HTTP/1.1" 200 -
```

```
thanh@ubuntu:~/Documents/rabac$ ryu-manager test.py
loading app test.py
loading app ryu.controller.ofp_handler
instantiating app test.py of PolicyRBAC
instantiating app ryu.controller.ofp_handler of OFPHandler
ALLOW 10.0.2.1(IT) → 10.0.3.10:80 | IT full access
ALLOW 10.0.2.1(IT) → 10.0.3.10:80 | IT full access
ALLOW 10.0.3.10(AppServer) → 10.0.2.1:53422 | Internal allow
ALLOW 10.0.3.10(AppServer) → 10.0.2.1:53422 | Internal allow
ALLOW 10.0.3.10(AppServer) → 10.0.2.1:53422 | Internal allow
DENY 10.0.1.1(Sales) → 10.0.3.10:80 | Sales outside work time
```

4. Kịch bản triển khai – Kiểm soát truy cập động dựa trên vai trò trong mạng SDN

- Link video demo: https://youtu.be/_dxlEk1mQis
- Các test case:
  - Test 1: IT request tài liệu đến AppServer.
  - Test 2: Sales request tài liệu đến AppServer (trong thời gian làm việc).
  - Test 3: Visitor request tài liệu đến AppServer.
  - Test 4: IT ssh đến AppServer.
  - Test 5: Sales ssh đến AppServer.
  - Test 6: Visitor ssh đến AppServer.
  - Test 7: Sales request tài liệu đến AppServer (ngoài thời gian làm việc).



5

NHẬN XÉT

5. Nhận xét

	Kịch bản 1	Kịch bản 2
Khả năng kiểm soát	Ổn định	Chi tiết, độ linh hoạt cao
Nhu cầu tài nguyên	Thấp	Tốn nhiều tài nguyên
Triển khai	Dễ dàng, phù hợp quy mô lớn, dễ mở rộng	Phức tạp, cần cân nhắc nếu có nhiều thuộc tính
Chính sách	Đơn giản hơn	Phức tạp, khó viết, khó bảo trì
Mức độ an toàn và tự động hóa	Ổn định	Cao hơn

THANK FOR YOUR LISTENING!